



Curso: Gestión de Riesgos de la Ciberseguridad

Freddy Alvarado Vargas

Profesor Área Operaciones y Tecnologías de la Información
Gerente de Operaciones y TI en empresas del sector
industrial, retail y telecomunicaciones.



1

Curso:
Gestión de Riesgos de la Ciberseguridad

Sesión 2
Identificación y Análisis de Riesgos

< 2 >

Freddy Alvarado Vargas
falvarado@esan.edu.pe

f in t

2

Sesión 2: Identificación y Análisis de Riesgos

1. Logro de aprendizaje de la sesión

Al finalizar la sesión, el participante será capaz de identificar activos críticos, amenazas y vulnerabilidades, así como analizar y evaluar riesgos de ciberseguridad mediante métodos cualitativos y cuantitativos, aplicando matrices de riesgo y metodologías internacionales para apoyar la toma de decisiones.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



3

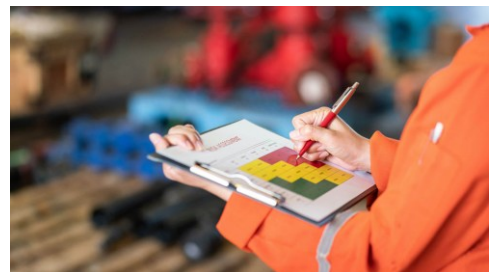
1. Introducción

La gestión de riesgos de ciberseguridad inicia con la comprensión de qué se debe proteger, de qué amenazas debe protegerse y cuáles son las debilidades que podrían ser explotadas.

Según NIST SP 800-30, la evaluación de riesgos permite identificar eventos potenciales que pueden afectar los objetivos organizacionales y estimar su impacto sobre los activos críticos.

Una adecuada identificación y análisis de riesgos permite:

- Priorizar inversiones en seguridad.
- Reducir pérdidas económicas.
- Cumplir requisitos regulatorios.
- Incrementar la resiliencia organizacional.
- Mejorar la continuidad del negocio.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



4

NIST SP 800-30

GUÍA PARA LA REALIZACIÓN DE EVALUACIONES DE RIESGOS

El NIST SP 800-30 (Rev. 1) es una guía publicada por el Instituto Nacional de Estándares y Tecnología (NIST) que proporciona un marco estructurado para que las organizaciones identifiquen, evalúen y gestionen los riesgos que pueden afectar el logro de sus objetivos.



NIST
National Institute of
Standards and Technology
U.S. Department of Commerce



5

01

Activos críticos de información de la SCM

¿Qué es un activo?

Es cualquier recurso que posee valor para la organización y cuya pérdida, alteración o indisponibilidad puede afectar el cumplimiento de sus objetivos.

6

Activos críticos de la información en SCM

1. Datos de clientes:

La información personal y financiera de los clientes es uno de los activos más críticos que deben ser protegidos. Los datos de los clientes pueden incluir información de identificación personal, información de contacto, información de pago, entre otros.



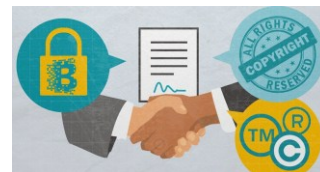
2. Información de inventario:

Información esencial para el funcionamiento de una cadena de suministros. Cualquier interrupción en la información de inventario puede tener un impacto significativo en la capacidad de la empresa para entregar los productos.



3. Propiedad intelectual:

Es un activo crítico para muchas empresas, especialmente para aquellas que operan en industrias altamente competitivas. La información de propiedad intelectual incluye patentes, marcas registradas, diseños, secretos comerciales y otra información confidencial.



freddy.alvarado@esan.edu.pe



7

Activos críticos de la información en SCM

4. Información financiera:

Información esencial para el funcionamiento de una empresa. Los ciberdelincuentes pueden utilizar la información financiera para realizar fraude o extorsión, lo que puede tener un impacto significativo en la empresa y en sus clientes.



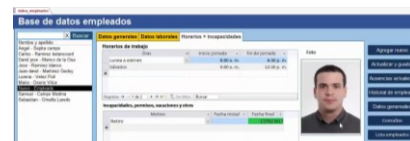
5. Información de proveedores:

Información importante para la gestión de la cadena de suministros. Cualquier interrupción en la información de proveedores puede tener un impacto en la capacidad de la empresa para entregar productos a tiempo.



6. Información de empleados:

Información crítica que debe ser protegida. La información de los empleados puede incluir información personal, información de contacto, información de pago, registros de empleo, historial de salud, y cualquier información sensible y confidencial.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



8

Tabla de Activos de Información de SCM

Activo de información	Descripción	Ubicación física o virtual	Responsable	Nivel de confidencialidad	Riesgos y amenazas
Datos de clientes	Información personal de los clientes, como nombres, direcciones, números de teléfono, correos electrónicos, historial de compras	Base de datos	Departamento de ventas y marketing	Alta	Acceso no autorizado, robo de datos, phishing, malware
Diseños de productos	Planos y diseños de productos	Servidor de diseño	Departamento de ingeniería	Muy alta	Acceso no autorizado, robo de propiedad intelectual, malware
Información financiera	Información sobre ingresos, gastos, cuentas bancarias y transacciones financieras	Software de contabilidad	Departamento de finanzas	Muy alta	Fraude, robo de datos, phishing
Información de proveedores	Información personal y financiera de los proveedores, contratos y acuerdos comerciales	Base de datos de proveedores	Departamento de compras	Alta	Acceso no autorizado, robo de datos, phishing
Contratos y acuerdos comerciales	Contratos, acuerdos de confidencialidad y otros documentos legales	Repositorio de documentos	Departamento legal	Muy alta	Acceso no autorizado, robo de propiedad intelectual
Planes de producción	Planes de producción y estrategias de fabricación	Servidor de planificación de producción	Departamento de operaciones	Muy alta	Acceso no autorizado, robo de propiedad intelectual, malware

Ejemplo referencial



Freddy Alvarado Vargas
falvarado@esan.edu.pe



Tabla Tipo de Activos de Información de SCM

Tipo de activo	Activo de información	Descripción	Ubicación física o virtual	Responsable	Nivel de confidencialidad	Riesgos y amenazas
Hardware	Servidores	Computadoras que proporcionan servicios de red y almacenamiento de datos	Sala de servidores	Equipo de TI	Muy alta	Robo, daño, pérdida de datos, interrupción del servicio
Hardware	Dispositivos móviles	Teléfonos inteligentes, tabletas y otros dispositivos móviles utilizados por los empleados	En posesión del usuario	Usuarios de la empresa	Alta	Pérdida, robo, acceso no autorizado, malware
Hardware	Equipos de red	Routers, switches y otros dispositivos de red utilizados para conectar computadoras y dispositivos	Sala de servidores	Equipo de TI	Alta	Acceso no autorizado, mal configuración, interrupción del servicio
Software	Sistemas operativos	Programas que controlan el hardware y proporcionan servicios de software	Computadoras y servidores	Equipo de TI	Muy alta	Vulnerabilidades de seguridad, malware, acceso no autorizado
Software	Aplicaciones de negocio	Programas utilizados para administrar procesos de negocio específicos, como finanzas, recursos humanos y producción	Computadoras y servidores	Departamentos específicos	Alta	Acceso no autorizado, vulnerabilidades de seguridad, interrupción del servicio
Software	Herramientas de colaboración	Software de correo electrónico, mensajería instantánea, videoconferencia y otras herramientas utilizadas para colaborar con otros	Computadoras y dispositivos móviles	Usuarios de la empresa	Media	Vulnerabilidades de seguridad, acceso no autorizado, malware



Ejemplo referencial

Freddy Alvarado Vargas
falvarado@esan.edu.pe



Nivel de Confidencialidad de los Activos de Información

Nivel de confidencialidad	Descripción
Muy Alta	Compromiso de confidencialidad catastrófico para la organización. Se trata de información altamente sensible y crítica, como secretos comerciales, propiedad intelectual, datos financieros y de investigación, información personal de clientes y empleados, entre otros.
Alta	Compromiso de confidencialidad significativo para la organización. Se trata de información confidencial y estratégica, como planes de negocio, estrategias de marketing, planes de producción y operación, entre otros.
Media	Compromiso de confidencialidad moderado para la organización. Se trata de información interna y sensible, como correos electrónicos, memorandos, informes, listas de contactos, entre otros.
Baja	Información de dominio público o no confidencial . Se trata de información que no tiene un impacto significativo en la organización si se pierde o se compromete su confidencialidad.

11

Dinámica grupal

Elabore un inventario de activos de información de su organización identificando el nivel de criticidad y los riesgos asociados.
Use plantilla en Excel (esan virtual)



Tiempo: 10min



12

02

Identificación de Amenazas y Vulnerabilidades


 Freddy Alvarado Vargas
falvarado@esan.edu.pe


13

Identificación de Amenazas y Vulnerabilidades

Amenaza

Evento o actor con capacidad para causar daño.

Ejemplos

- Ciberdelincuentes
- Hacktivistas
- Empleados maliciosos
- Errores humanos
- Desastres naturales

Vulnerabilidad

Debilidad que puede ser explotada por una amenaza.

Ejemplos

- Software sin actualizar
- Contraseñas débiles
- Falta de MFA
- Mala configuración cloud
- Ausencia de backups

Relación práctica

Activo	Amenaza	Vulnerabilidad
Portal municipal	Ransomware	Sistema sin parches
Base de datos tributaria	Robo de datos	Contraseñas débiles
Servidor web	Ataque web	Vulnerabilidades OWASP Top 10
Red interna	Movimiento lateral	Ausencia de segmentación


 Freddy Alvarado Vargas
falvarado@esan.edu.pe


14

Las 10 vulnerabilidades críticas de OWASP

El **OWASP Top 10** es el documento de referencia global que recopila las **diez vulnerabilidades de seguridad más críticas** en las aplicaciones web. Diseñado por la fundación sin fines de lucro *Open Web Application Security Project* (OWASP), sirve para que desarrolladores y expertos refuerzen la seguridad del software desde su creación. [\[1, 2, 3, 4, 5\]](#)

1. **Control de acceso roto:** Los usuarios acceden a funciones o datos fuera de sus permisos establecidos. [\[1, 2, 3, 4\]](#)
2. **Fallas criptográficas:** Exposición de datos sensibles por falta de cifrado o uso de algoritmos obsoletos. [\[1, 2\]](#)
3. **Inyección:** Entrada de datos dañinos (como SQL o XSS) que el sistema ejecuta como comandos válidos. [\[1, 2, 3, 4, 5\]](#)
4. **Diseño inseguro:** Defectos desde la arquitectura del código que no pueden solucionarse con configuraciones posteriores. [\[1\]](#)
5. **Mala configuración de seguridad:** Falta de endurecimiento (*hardening*) del sistema o mantener credenciales por defecto activas. [\[1, 2, 3\]](#)
6. **Componentes vulnerables y obsoletos:** Uso de librerías, dependencias o módulos desactualizados que contienen fallas conocidas. [\[1, 2, 3, 4, 5\]](#)
7. **Fallos de identificación y autenticación:** Debilidades al validar la identidad del usuario, facilitando el robo de sesiones. [\[1, 2\]](#)
8. **Fallas de integridad de datos y software:** Código o infraestructura (como pipelines CI/CD) que no verifica la legitimidad de las actualizaciones. [\[1, 2, 3, 4\]](#)
9. **Fallas en el registro y monitoreo:** Incapacidad de detectar, alertar o registrar actividades sospechosas o brechas activas en tiempo real. [\[1, 2\]](#)
10. **Falsificación de solicitudes del lado del servidor (SSRF):** Manipulación de la aplicación web para que realice peticiones involuntarias hacia otros servidores internos o externos. [\[1, 2, 3\]](#)



Freddy Alvarado Vargas
falvarado@esan.edu.pe



15

Riesgos de los Activos Críticos de la información



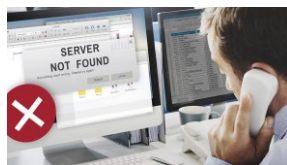
1. Ciberataques:

Accesos ilícitos de los ciberdelincuentes a información confidencial a través de métodos, como phishing, malware, ransomware, entre otros.



2. Robo y pérdida de datos:

Mediante robo de dispositivos, la eliminación accidental de información o la exposición de datos a través de la nube o el correo electrónico.



3. Interrupciones del servicio:

Pueden impactar en la capacidad de una empresa para entregar productos a tiempo y causados por ataques cibernéticos, fallos de hardware, errores humanos, entre otros.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



16

Riesgos de los Activos Críticos de la información



4. Errores humanos:

Causa común de pérdida de datos y otros problemas de seguridad. Por ejemplo, un empleado puede enviar información confidencial a la dirección de correo electrónico equivocada o hacer clic en un enlace malicioso sin saberlo.



5. Desastres naturales:

Desastres naturales, como inundaciones, terremotos y tormentas, pueden causar daños físicos a los servidores y otros equipos que contienen información crítica, lo que puede interrumpir el servicio y poner en riesgo la seguridad de la información.



6. Amenazas internas:

Como es el caso de empleados descontentos o ex empleados, pueden representar un riesgo para la seguridad de la información.

Freddy Alvarado Vargas
falvarado@esan.edu.pe



17

Tipos de Hackers



Freddy Alvarado Vargas
falvarado@esan.edu.pe



18

Y la amenaza no son sólo los hackers...



19



Y sus colaboradores...?



20

esan GRADUATE SCHOOL OF BUSINESS

Vulnerabilidades y amenazas

Análisis, valoración de riesgos y controles de ciberseguridad: Vulnerabilidades y amenazas

Freddy Alvarado Vargas
falvarado@esan.edu.pe

https://www.youtube.com/watch?v=mHAdqq_7FXg

21



03

Métodos de Análisis de Riesgos



Freddy Alvarado Vargas
falvarado@esan.edu.pe



22

4. Métodos de Análisis de Riesgos

La evaluación de riesgos puede realizarse mediante enfoques cualitativos o cuantitativos.

4.1 Método Cualitativo

Utiliza escalas descriptivas.

Probabilidad		Impacto	
Valor	Descripción	Valor	Descripción
1	Muy Baja	1	Insignificante
2	Baja	2	Menor
3	Media	3	Moderado
4	Alta	4	Mayor
5	Muy Alta	5	Crítico

Ejemplo

Riesgo: "Ransomware en sistema de pagos municipales"

Probabilidad = 4 (Alta)

Impacto = 5 (Crítico)

Nivel de riesgo:

$\text{Riesgo} = \text{Probabilidad} \times \text{Impacto} = 4 \times 5 = 20$

Resultado: Riesgo Muy Alto.

4. Métodos de Análisis de Riesgos

4.2 Método Cuantitativo

Permite expresar riesgos en términos monetarios.

SLE (Single Loss Expectancy)

Representa la pérdida económica de un incidente individual.

Fórmula:

$$\text{SLE} = \text{AV} \times \text{EF}$$

Donde:

AV = Asset Value (Valor del activo)

EF = Exposure Factor (Porcentaje de pérdida)



Ejemplo

Valor del sistema:

USD 500,000

Impacto estimado:

40%

Cálculo:

$$\text{SLE} = 500,000 \times 0.40$$

$$\text{SLE} = \text{USD } 200,000$$

4.2 Método Cuantitativo

Permite expresar riesgos en términos monetarios.

ALE (Annual Loss Expectancy)

Representa la pérdida anual esperada.

Fórmula:

$$ALE = SLE \times \text{times ARO}$$

Donde:

ARO = Annual Rate of Occurrence

(*) ARO (Tasa de Ocurrencia Anual)

Ejemplo

$$SLE = \text{USD } 200,000$$

$$ARO = 0.5$$

$$ALE = 200,000 \times 0.5$$

$$ALE = \text{USD } 100,000 \text{ anuales}$$

Interpretación

Si un control cuesta USD 30,000 y reduce significativamente el riesgo, resulta económicamente justificable.

5. Matriz de Riesgos.

La matriz de riesgos permite visualizar y priorizar los riesgos según su probabilidad de ocurrencia y su impacto sobre la organización.

Impacto \ Probabilidad	1 Muy Baja	2 Baja	3 Media	4 Alta	5 Muy Alta
5 Crítico	Medio	Alto	Alto	Crítico	Crítico
4 Mayor	Medio	Medio	Alto	Alto	Crítico
3 Moderado	Bajo	Medio	Medio	Alto	Alto
2 Menor	Bajo	Bajo	Medio	Medio	Alto
1 Insignificante	Bajo	Bajo	Bajo	Medio	Medio

Leyenda de niveles de riesgo

Nivel de Riesgo	Acción recomendada
Crítico	Acción inmediata. Implementar controles urgentes y seguimiento permanente.
Alto	Elaborar e implementar un plan de tratamiento en el corto plazo.
Medio	Monitorear periódicamente y evaluar controles adicionales.
Bajo	Aceptar el riesgo y mantener vigilancia básica.

Ejemplos de aplicación

Riesgo	Probabilidad	Impacto	Nivel
Ransomware en sistema de pagos municipales	Alta (4)	Crítico (5)	Crítico
Phishing a funcionarios públicos	Muy Alta (5)	Moderado (3)	Alto
Falla de un servidor secundario	Baja (2)	Menor (2)	Bajo
Acceso no autorizado a base de datos tributaria	Media (3)	Crítico (5)	Alto
Ataque DDoS a portal Institucional	Alta (4)	Mayor (4)	Alto

Caso de Discusión



Caso: Brecha de datos en Equifax (2017)

Antecedentes

Equifax es una de las principales agencias de información crediticia del mundo. En 2017 sufrió una de las brechas de datos más importantes de la historia.

Datos del incidente

Información comprometida:

- 147 millones de personas.
- Nombres completos.
- Fechas de nacimiento.
- Números de seguro social.
- Direcciones.
- Información financiera.

Vulnerabilidad explotada

Apache Struts (CVE-2017-5638). Existía un parche disponible que no fue aplicado oportunamente.

Impactos

Financiero

Más de USD 1,400 millones entre:

- multas,
- litigios,
- compensaciones,
- remediación tecnológica.

Reputacional

- Pérdida de confianza global.
- Renuncia de ejecutivos.
- Investigación del Congreso de EE.UU.

Operacional

- Programas masivos de respuesta.
- Auditorías de seguridad.
- Transformación de procesos.

Freddy Alvarado Vargas
falvarado@esan.edu.pe



27

Ciberamenazas



Freddy Alvarado Vargas
falvarado@esan.edu.pe



<https://www.youtube.com/watch?v=TtVDO0qc9M>

28

Análisis de riesgos AMFE



Freddy Alvarado Vargas
falvarado@esan.edu.pe



29



Análisis de riesgo AMFE

El AMFE (Análisis Modal de Fallos y Efectos), conocido internacionalmente como FMEA (Failure Mode and Effects Analysis), es una metodología preventiva utilizada para identificar posibles fallos, evaluar sus efectos y priorizar acciones de mejora antes de que ocurran incidentes.

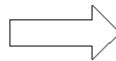
En ciberseguridad, el AMFE resulta especialmente útil para analizar vulnerabilidades, amenazas y controles en procesos críticos.



Gravedad del fallo (S)

Probabilidad de ocurrencia (O)

Probabilidad de no detección (D)



Número de Prioridad de Riesgo:

$$NPR = S * O * D$$

Dependiendo de la complejidad del proceso y producto, el AMFE debe ser preparado por un equipo de expertos en diversas áreas como: diseño, manufactura, ensamble, servicio, calidad, seguridad, etc.

Freddy Alvarado Vargas
falvarado@esan.edu.pe



30

DESARROLLO DE UN PROCESS FMEA

Severity (S) : Es una evaluación de la severidad del efecto del modo potencial de falla , la severidad esta relacionada unicamente con el efecto. La severidad debe estar estimada en una **escala del 1 al 10**.

De acuerdo a la tabla siguiente, el equipo debe estar de acuerdo en el criterio de evaluación y el sistema de prioridades.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



31

Efecto	Criterio: SEVERIDAD DEL IMPACTO	Escala
Peligroso: Sin alarma	Podría poner en riesgo a las personas. El modo de falla afecta el proceso y/o transgrede las regulaciones gubernamentales. La falla podría ocurrir SIN previo aviso o alarma.	10
Peligroso: Con alarma	Podría poner en riesgo a las personas. El modo de falla afecta el proceso y/o transgrede las regulaciones gubernamentales. La falla podría ocurrir CON aviso o alarma.	9
Muy Alto	Interrupción grave en el proceso. El 100% de los activos (información) podría perderse (desperdicio)	8
Alto	Interrupción importante en el proceso. La información tendría que ser revisada y parte de la misma podría perderse. El proceso podría continuar con bajo nivel de desempeño.	7
Moderado	Interrupción moderada en el proceso. Parte de la información podría perderse (desperdicio). El proceso podría continuar sin alcanzar el mejor desempeño. Disconformidad en el Cliente	6
Bajo	Interrupción menor en el proceso. El 100% de la información tendría que ser recuperada. Proceso puede continuar con un nivel de desempeño bajo.	5
Muy Bajo	Interrupción menor en el proceso. La información tendría que ser revisada y parte de la misma tendría que ser recuperada. Obtención de información con errores o distorsionada que podría ser cuestionada por los usuarios.	4
Menor	Interrupción menor en el proceso. Una porción de la información tendría que ser recuperada. Obtención de información con errores que podría ser detectada y cuestionada por el promedio de usuarios.	3
Mucho Menor	Interrupción mínima en el proceso. Una porción de la información tendría que ser recuperada entro del proceso. Obtención de información distorsionada y detectada por muy pocos usuarios	2
Sin efecto	No afecta el proceso.ni a la información	1



Freddy Alvarado Vargas
falvarado@esan.edu.pe



32

Análisis AMFE...

Potencial Causes(s) /Mechanism(s) of Failure :

Identifica **causas raíz**. Son las razones por las cuales las fallas pueden ocurrir, descritas en terminos de algo que puede ser corregido o controlado. Listar cada causa de falla asignable a cada efecto de falla potencial, las causas deben ser descritas de modo que pueda definirse una acción preventiva eficaz.

Ejemplos, *Desarrollo*: error de programación, ingreso de datos errados, deficiente integración. *Infraestructura de TI*: malas condiciones, mantenimiento, desconocimiento, accesos, etc. *Usuario*: deficiente comportamiento de ciberseguridad.

Al describir la causa:

“Especificar y evitar generalidades”



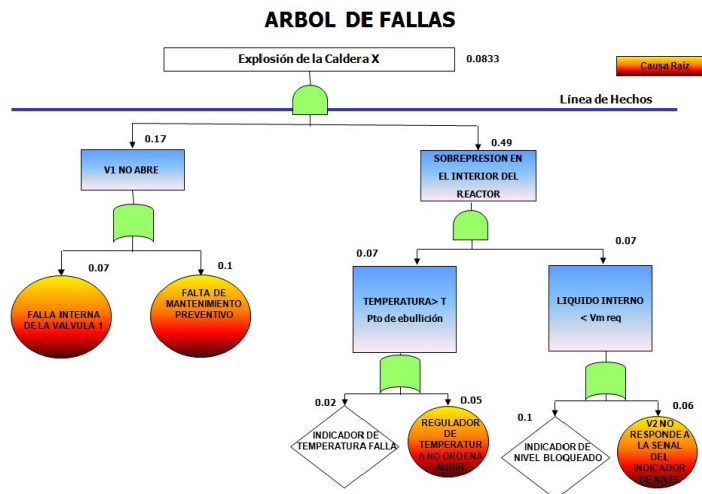
Freddy Alvarado Vargas
falvarado@esan.edu.pe



33

DETERMINACION DE CAUSAS

Análisis Causa Efecto / Arbol de Fallas



Freddy Alvarado Vargas
falvarado@esan.edu.pe

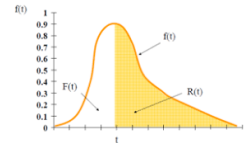


34

Análisis AMFE...

Occurrence (O) Es la frecuencia en que una causa específica de falla puede ocurrir, se evalúa en una escala del 1 al 10 según la siguiente tabla:

Probabilidad de Falla	Posibilidad de Falla	Cpk	Escala
Muy Alto: La Falla es casi inevitable	≥ 1 in 2	< 0.33	10
	1 in 3	≥ 0.33	9
Alto: Generalmente asociado con procesos similares al anterior y que fallan con frecuencia	1 in 8	≥ 0.51	8
	1 in 20	≥ 0.67	7
Moderado: Generalmente asociado con procesos similares al anterior y que han tenido fallas ocasionales pero no en grandes proporciones	1 in 80	≥ 0.83	6
	1 in 400	≥ 1.00	5
	1 in 2,000	≥ 1.17	4
Bajo: Fallas aisladas asociadas con procesos similares	1 in 15,000	≥ 1.33	3
Muy Bajo: Solamente Fallas aisladas asociadas con procesos casi idénticos	1 in 150,000	≥ 1.5	2
Remoto: Falla poco probable. No hay fallas asociadas a procesos	≤ 1 in 1,500,000	≥ 1.67	1



Freddy Alvarado Vargas
falvarado@esan.edu.pe



35

Análisis AMFE...

Current Process Controls : Son las descripciones de los controles que previenen la posibilidad de que el modo de falla potencial ocurra, o bien detectan el modo de falla una vez ocurrido. Estos controles pueden ser físicos, electrónicos, preventivos como Poka Yoke(*) o analítico como el Control Estadístico del Proceso. Existen tres tipos de controles de proceso :

- Previenen la causa del modo de falla , o reducen su ocurrencia.
- Detectan la causa
- Detectan el modo de falla.

Detection (D) : Es la evaluación de la probabilidad de que los controles de proceso detecten el modo de falla. Se evalúa en una escala del 1 al 10 según la siguiente tabla:

(*) Poka Yoke, sistema japonés orientado a prevenir y evitar errores. Utiliza dispositivos en el proceso para la Detección de errores (sistema "anti-tonto") y Sistemas de alarma (Andon).



Freddy Alvarado Vargas
falvarado@esan.edu.pe



36

DETECCION



Nivel de Detección	Probabilidad del Test de Detección de Fallas del proceso antes de pasar a la siguiente actividad	Escala
Casi imposible	Test de contenido detecta < 80% de fallas	10
Muy remoto	Test de contenido debe detectar 80% de fallas	9
Remoto	Test de contenido detecta < 82.5% de fallas	8
Muy bajo	Test de contenido detecta < 85% de fallas	7
Bajo	Test de contenido detecta < 87.5% de fallas	6
Moderado	Test de contenido detecta < 90% de fallas	5
Moderadamente Alto	Test de contenido detecta < 92.5% de fallas	4
Alto	Test de contenido detecta < 95% de fallas	3
Muy Alto	Test de contenido detecta < 97.5% de fallas	2
Casi Certero	Test de contenido detecta < 99.5% de fallas	1

Freddy Alvarado Vargas
falvarado@esan.edu.pe



37

Análisis AMFE...

Risk Priority Number (RPN): El RPN es el producto de las calificaciones de: Severidad (S) , Ocurrencia (O) y Deteccion (D)

$$RPN = (S) \times (O) \times (D)$$

Recommended Action(s): Acciones correctivas deben ser tomadas, principalmente para las operaciones con el RPN mas alto.

Responsibility (for the Recommended Action): Introducir el equipo o individuo responsable de aplicar las recomendaciones.

Actions Taken: Después de que las acciones hayan sido tomadas, se da una breve explicación de las acciones tomadas .

Resulting RPN: Después de que la acciones correctivas fueron tomadas, se re-evalua la severidad, ocurrencia y deteccion, calculando nuevamente el RPN.

PRiORiDaDeS

- 1.
- 2.
- 3.



EMPEZAR A CORREGIR LAS FALLAS CON LOS RPN MAS ALTOS

Freddy Alvarado Vargas
falvarado@esan.edu.pe



38

AMFE

Project No. _____ Sheet _____ of _____
 Subsystem: _____ Date: _____
 System: _____ **Sverdrup Technology, Inc.** Prep. by: _____
Failure Modes & Effects Analysis Rev. by: _____
 Probability Interval: _____ Approved by: _____
 Operational Phase(s): _____ FMEA No. : _____

IDENT. NO.	ITEM/ FUNCTIONAL IDENT.	FAILURE MODE	FAILURE CAUSE	FAILURE EFFECT	INITIAL RISK	RISK ASSESSMENT			ACTION REQUIRED / REMARKS
						SEV	PROB	RISK CODE	

Sverdrup Technology, Inc.
Worksheet

Tabla AMFE de Ciberseguridad

Proceso / Activo	Modo de fallo (riesgo)	Efecto potencial	Causa potencial	S	O	D	NPR
Portal de pagos web	Ataque ransomware	Interrupción del servicio	Software desactualizado	10	6	7	420
Base de datos tributaria	Robo de información	Fuga de datos personales	Contraseñas débiles	9	7	6	378
Acceso de funcionarios	Compromiso de credenciales	Acceso no autorizado	Phishing	8	8	5	320
Infraestructura de red	Movimiento lateral	Propagación del ataque	Falta de segmentación	9	6	6	324
Centro de datos	Pérdida de información	Imposibilidad de recuperación	Backups insuficientes	10	4	8	320
Servicios cloud	Exposición de información	Incumplimiento legal	Configuración incorrecta	8	5	7	280

Análisis AMFE



- Utilice la plantilla AMFE en el Esan Virtual y desarrolle al menos dos riesgos, calculando el RPN y la mejora de control para mitigar el riesgo.
- Tiempo 10 min

Conclusión de la sesión

1. Para gestionar los riesgos de ciberseguridad, primero es necesario identificar y conocer los activos más importantes de la organización.
2. Los riesgos aparecen cuando una amenaza aprovecha una vulnerabilidad y afecta un activo crítico.
3. El análisis cualitativo y cuantitativo ayuda a comprender mejor los riesgos y a tomar decisiones más informadas.
4. La matriz de riesgos permite priorizar cuáles riesgos requieren atención inmediata y cuáles pueden ser monitoreados.
5. Casos como Equifax demuestran que una vulnerabilidad no gestionada puede generar grandes pérdidas económicas, legales y reputacionales.





"En un mundo cada vez más digital, el riesgo es inevitable, pero la vulnerabilidad es gestionable. Las organizaciones que identifican, analizan y gestionan sus riesgos de manera proactiva transforman la incertidumbre en una ventaja estratégica."

Referencias bibliográficas

- National Institute of Standards and Technology. (2012). *Guide for Conducting Risk Assessments (NIST SP 800-30 Rev. 1)*. U.S. Department of Commerce.
- OWASP Foundation. (2023). *OWASP Risk Rating Methodology*. https://owasp.org/www-community/OWASP_Risk_Rating_Methodology
- National Institute of Standards and Technology. (2023). *Risk Management Framework (RMF)*. <https://csrc.nist.gov/projects/risk-management/about-rmf>
- ENISA. (2023). *ENISA Threat Landscape 2023*. European Union Agency for Cybersecurity.
- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO.





*Y nunca olvidar nuestra
responsabilidad con el
planeta...*

Muchas gracias!!

Freddy Alvarado Vargas

Profesor Área Operaciones y TI
falvarado@esan.edu.pe